

What is the ISO 27001 standard?

ISO 27001 standard ISO 27001 is an information security management system released by the International Organization for Standardization (ISO). The latest version is ISO 27001:2022. ISO/IEC 27001:2022 was developed to help businesses build, establish, operate, apply, monitor, review, maintain, and improve information systems to ensure the confidentiality of internal information within the enterprise. At the same time, the ISO 27001 standard also helps prevent cases of illegal data theft.

Regardless of industry, type, or size, ISO 27001 is applicable to all businesses, organizations, and institutions. In particular, for business models in fields such as information technology, telecommunications companies, financial institutions, and banks, ISO 27001:2022 is recommended to enhance the security of both hard copy and digital data.



Benefits of implementing ISO 27001 for businesses

For any business, information assets are incredibly valuable. Therefore, implementing ISO/IEC 27001 will help businesses and organizations protect their information assets more effectively.

In addition, the ISO 27001 standard offers many benefits to businesses and organizations, such as:

- Ensuring the security of internal company information, partner information, and customer information, preventing leaks to external parties;
- Enhance the organization's ability to ensure the smooth and secure flow of information;
- This demonstrates that the business complies with all applicable regulations and laws regarding cybersecurity;
- Enhance the image and reputation of the business with partners and customers when collaborating with and using the business's services and products;
- Adherence to ISO 27001 standards will significantly increase a company's ability to expand into international markets;
- Increase competitive advantage over other strong competitors in the same field in the market;
- To demonstrate independence in internal control processes and meet the requirements of corporate governance and business operations;
- Enhance the stability and continuous improvement of the ISMS;
- It helps businesses detect potential risks early and take prompt corrective and remedial measures to avoid potential losses for the business and its customers.
- Raise awareness among all employees in the company about the importance of information security in the workplace.



Some notes on the ISO 27001:2013 standard.

From the date of certification, the ISO 27001 certificate is valid for 3 years. During these 3 years, there will be two annual audits. Therefore, businesses should maintain and continuously improve their information security management system to avoid having their certificate revoked.

The ISO 27001 standard shares the same high-level structure (HLS), making it compatible and applicable concurrently with other management systems such as ISO 14001 and ISO 9001.

For the most effective implementation and application of ISO/IEC 27001, it requires the commitment of the company's leadership as well as seamless coordination between departments within the organization to build and maintain the system.

Requirements for the ISO 27001 standard

Similar to other ISO standards, ISO 27001 also has basic requirements for businesses to follow the PDCA process to achieve an effective information security management system. The process approach in ISO 27001 emphasizes the importance of:

- Understand the information security requirements of the business and the urgency of developing security policies and objectives.
- Implement measures to address information security risks in a context where information is easily lost or stolen.
- Conduct monitoring and review activities to assess the effectiveness of the information security management system.
- Continuously improve the information security management system.

These are the four ISO 27001 requirements that businesses need to understand when implementing the system.



Yêu cầu của tiêu chuẩn ISO 27001

ISO 27001 certification process

The ISO 27001 implementation process includes the following steps:

- Step 1: Register for ISO/IEC 27001 certification with a reputable certification organization.

When applying for certification, businesses need to provide information such as scale, scope of production, current industry, number of employees, existing processes, etc.,

so that the certification body can select auditors with experience suitable for the business's processes. This also helps the certification body determine the scope and timeframe of the audit.

- Step 2: Sign the contract and conduct a preliminary assessment (if necessary).

The certification body assesses the level or completeness of the company's implementation. After the preliminary assessment results are available, the certification body will develop a list of items that need to be addressed before the ISO 27001:2022 certification audit.

- Step 3: ISO 27001:2022 Certification Assessment

Phase 1: The certification body reviews the company's procedures, records, and documents and may conduct an on-site assessment. Phase 1 assessments typically evaluate readiness, focusing on key components of the system.

Phase 2: Comprehensive assessment of the information security management system and representative sampling of the information security management process within the enterprise. The purpose of the Phase 2 assessment is to determine whether the information security management system is fully implemented and effective within the enterprise before reviewing the application for ISO 27001 certification.

- Step 4: Review, correct, and verify the documentation.

If any non-conformities are identified during the certification assessment process, your company will have 90 days to rectify them.

- Step 5: Issuing the ISO 27001 certificate.

If the assessment confirms compliance, the business will be granted an ISO 27001 certificate valid for 3 years.

- Step 6: Annual Monitoring

The above isSteps to implement ISO 27001During the 3-year validity period, there will be two annual inspections.